

Privacy Requirements

Standalone extract of the Phase 1 report

CSE 347/652 | DES 306/525 Usable Security and Privacy
IIIT-Delhi · Monsoon 2026 · Instructor: Dr. Arun Balaji Buduru

Phase 1: User Studies to evolve Requirements, Design and Workflows
Submission: 4 October 2026

Team: [INSERT TEAM MEMBER NAMES AND ROLL NUMBERS]

Primary research status: instruments complete; fieldwork data not yet collected. All placeholders are marked [DATA REQUIRED]. No primary data has been fabricated.

21. Privacy Requirements

Grounded in DPDP Act 2023 [22], ISO/IEC 29100 [26] and Privacy by Design [27].

ID	Requirement	Principle	Rationale / user need	Pri	Prototype feature	Phase 2 evaluation
PRIV-01	Data minimisation: collect and store only the fields listed in SEC-14; visitors: name, host, purpose category, window, contact channel (for pass delivery only).	Collection limitation	Reduce breach impact; Ramesh does not want to hold personal data.	M	Screens 13, 17	Schema review
PRIV-02	Purpose limitation: entry data is used only for access decisions, security incident investigation and system integrity. It is not used for attendance, academic monitoring, or behavioural analytics without a separate, documented policy decision and notice.	Purpose specification	Q15b concern [DATA REQUIRED]; trust.	M	Screen 20 privacy notice text	Policy document; API scopes
PRIV-03	Role-based visibility: Guard sees photo, first name, role, decision, next step. Supervisor adds gate status and alert queue. Issuer sees identity fields needed to issue. Auditor sees pseudonymous logs; re-identification per PRIV-06. Student sees own data only.	Use limitation	Q14c [DATA REQUIRED].	M	Screens 5, 16, 17, 19, 20	Role-based UI/API tests
PRIV-04	Pseudonymous logging: access events store a credential pseudonym, not name or roll number; the mapping is held in a separately access-controlled table.	Minimisation; unlinkability	Routine log review reveals no identities.	M	Screen 19	Log inspection
PRIV-05	Retention limits: access events retained 90 days then deleted (configurable; justify any longer period); flagged/incident events retained until case closed + 1 year; visitor records deleted 30 days after visit; revoked credential records retained 1 year for fraud detection then deleted. Deletion is automatic and logged.	Retention limitation	DPDP erasure obligation [22].	M	Screen 20 shows retention policy	Verify scheduled purge
PRIV-06	Re-identification of a pseudonymous log entry requires Auditor role, a recorded case reference and justification, and is itself logged and visible to a second administrator.	Accountability	Prevent casual look-ups of "where was student X".	M	Screen 19 re-identify dialog	Attempt without justification → refused; log check
PRIV-07	Transparency notice: students and visitors are told, at enrolment and on the app/pass, what is collected, why, who can see it, how long it is kept, and how to access or query it.	Openness	Trust (Q15c [DATA REQUIRED]).	M	Screen 20; enrolment text	Content review
PRIV-08	Individual access: a student can view their own entry events and credential status, and request correction of identity data.	Individual participation	Q14b [DATA REQUIRED]; DPDP right of access [22].	S	Screen 20	Functional test
PRIV-09	Visitor data: no public register; visitor's phone/e-mail is used only to deliver the pass and is not shown to the guard; deleted per PRIV-05.	Minimisation	Dr. Fernandes persona; H6.	M	Screens 13–15	UI/API inspection
PRIV-10	Privacy-preserving UI: the guard screen is angled/hooded so bystanders cannot read it; the user-facing indicator shows only colour/icon and a short message, never the name; denial messages do not state the reason to bystanders.	Confidentiality in public space	Meher: dignity; public interrogation today.	M	Screens 4–9 user-facing vs guard-facing split	Field check of placement; UI review
PRIV-11	Secure storage: personal data and key material encrypted at rest (AES-256; keys in HSM/KMS or OS keystore); photo store separately access-controlled.	Security safeguards	DPDP reasonable safeguards [22].	M	—	Config review
PRIV-12	No secondary sharing: entry data is not shared with third parties or other campus systems without a documented legal basis and notice.	Disclosure limitation	Q15b.	M	Screen 20 notice	Policy and API review

21.1 Visibility comparison: what each role sees

Data item	Student (own)	Security guard	Supervisor	Issuer / ID cell	Auditor	Policy admin
Photo on file	✓	✓ (on tap only)	✓ (on tap/alert only)	✓ (when issuing)	On re-identify only	✗
First / display name	✓	✓	✓	✓	On re-identify only	✗
Full name	✓	✗	✗	✓	On re-identify only	✗
Roll number / employee ID	✓	✗	✗	✓	On re-identify only	✗
Programme / department	✓	✗	✗	✓	On re-identify only	✗ (roles only)
Role (student/staff/visitor)	✓	✓	✓	✓	✓	✓ (as policy subject)
Hostel	✓	✗	✗	✗ (not stored)	✗	✗
Phone / e-mail	✓	✗	✗	✗ (not stored for students; visitor contact only for pass delivery)	✗	✗

Data item	Student (own)	Security guard	Supervisor	Issuer / ID cell	Auditor	Policy admin
Home address / emergency contact	✗ (not stored)	✗	✗	✗	✗	✗
Credential status (active/revoked/expired)	✓ (own)	Decision only	Decision only	✓	✓ (pseudonymous)	✗
Revocation reason	✓ (own, generic)	✗	✗	✓	✓	✗
Own entry events	✓	✗	✗	✗	✓ (pseudonymous; re-identify with justification)	✗
Other people's entry events	✗	✗	Gate counts only	✗	✓ (pseudonymous)	Aggregates only
Decision + reason code + next step	✓ (own)	✓	✓	✗	✓	✗
Visitor host name	—	✓	✓	—	✓	✗
Visitor contact	—	✗	✗	Approver only, for delivery	✗	✗
Policy rules	Own applicable summary	✗	Read	✗	Read	✓ Edit